VULNERABILITY ASSESMENT REPORT

Read-Only Security Audit of a Public Web Application

Name: Ruth Getnet

Date: April 4, 2026

Website Tested: OWASP Juice Shop Public Demo (https://demo.owasp-juice.shop)

EXECUTIVE SUMMARY

A read-only vulnerability assessment was conducted on the public OWASP Juice Shop demo (https://demo.owasp-juice.shop). The conduct of this security assessment was undertaken in the cyber-friendly Kali Linux operating system, and it uncovered network exposure, security header configuration, cookie security configuration, and client-side traffic response assessments without performing destructive exploitation. The network exposure assessment revealed open ports that could expose the site by enabling unauthorized communication with the server. It was able to answer the question: “Is the target website showing too much to the public?” The security header and cookie security configuration assessments ensured that the website provides sufficient security instructions to the browser (Chrome, Edge, etc.) and reminds it to keep the cookies safe and protected. (Cookies are like name tags that are sent to the browser, and their leakage might cause issues like giving the attacker the ability to pretend to be the user, and many more.) The client-side traffic response assessment is performed by watching the conversation between the website and the visitor’s browser, using the DevTools on a browser. Finally, in this assessment, I wanted to make sure that the website isn’t exposing too much to the public. In the overall assessment, I have detected 9 vulnerabilities that could be categorized as low/informational-level, medium-level, and high-level vulnerabilities. Some considerable remediation tips have also been included at the end of the individual vulnerability descriptions.

SCOPE & METHODOLOGY

Scope:

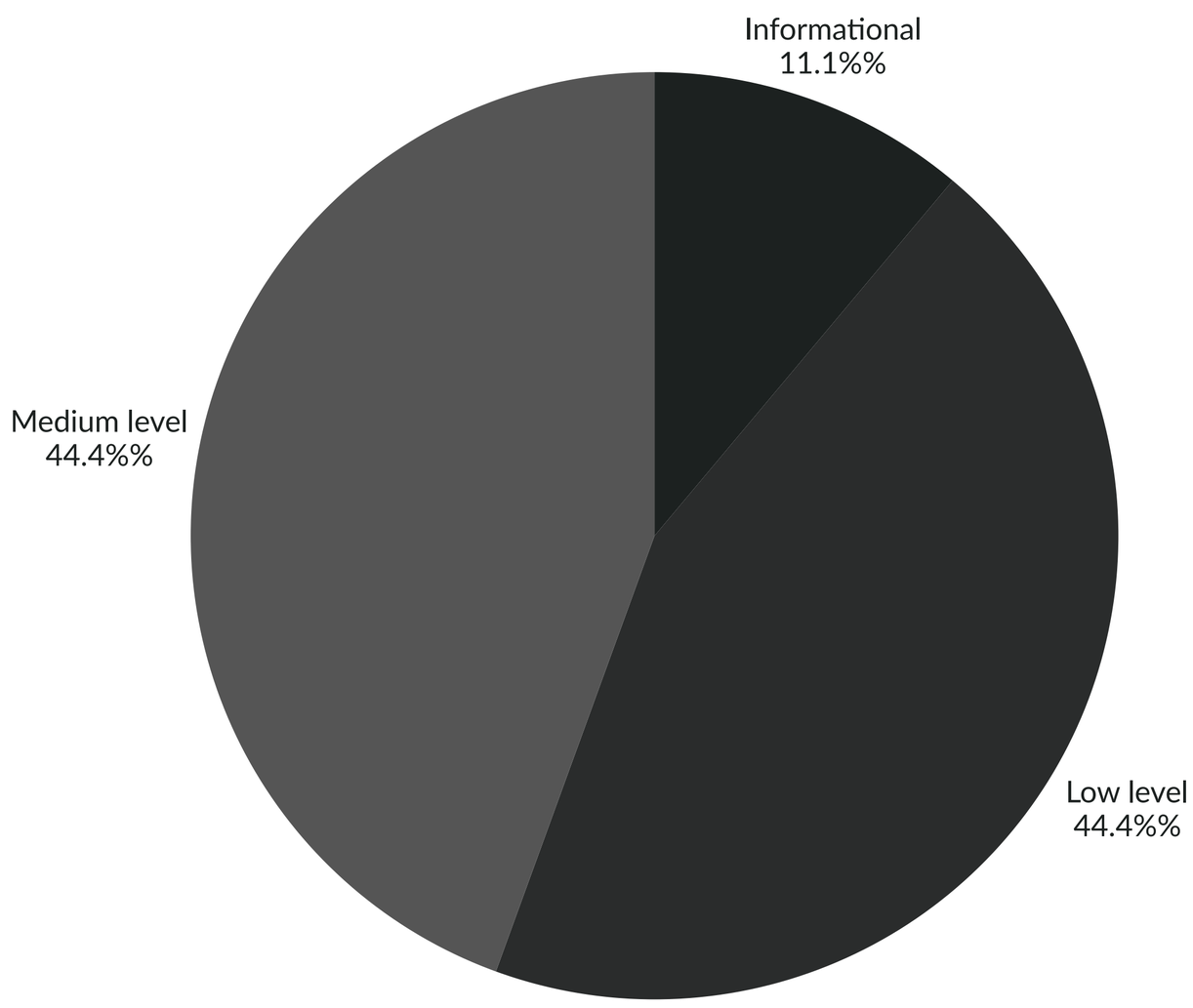
- This assessment covered public-facing pages only, passive scanning with no activity that can harm the website, header checks, and configuration analysis. It was against the application of any Pen Tests such as login bypass, brute force attacks, DoS, XSS injection and any exploitation towards the website under assessment.

Tools used:

- Nmap: for basic port & exposure analysis
- Firefox / Chrome: for website interaction and visual review
- Browser DevTools: to inspect/assess headers, cookies, and client-side issues
- Canva: for report design and presentation

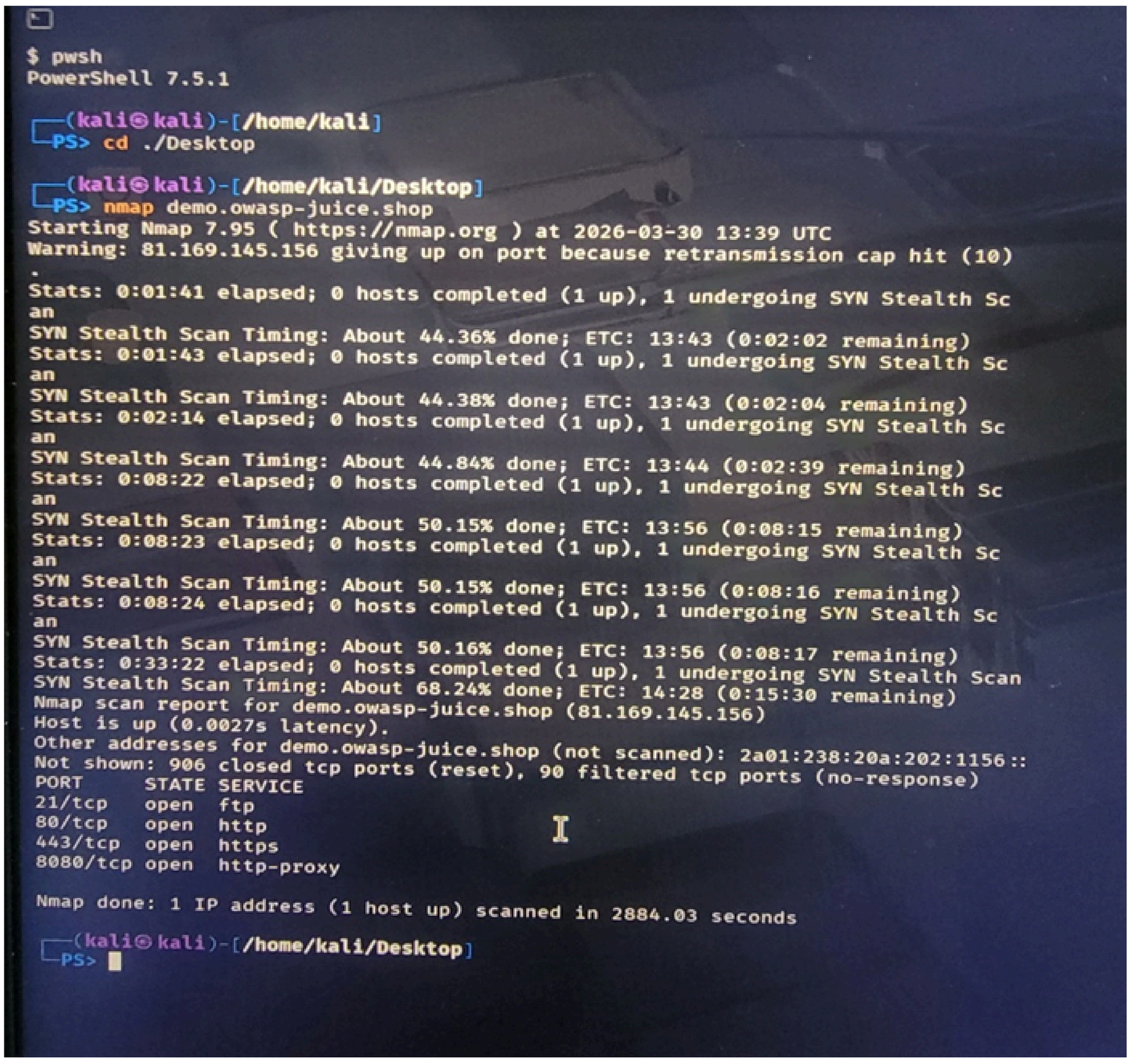
Risk Summary

Total risk findings	Informational	Low level	Medium level	High level
9	1	4	4	-



Nmap SCAN FINDINGS

Finding 1: Multiple Publicly Exposed Services



Nmap SCAN FINDINGS

Finding 1: Multiple Publicly Exposed Services

Risk level: Medium

Explanation: As a result of my Nmap scan in the Kali Linux environment, I have found 4 open TCP ports actively listening to the server. These are port 21-FTP, 80-HTTP, 443-HTTPS, and 8080-alternate web/proxy style HTTP service. A normal website would typically have two open TCP ports the port 80 and 443 which provide standard web services. The exposure of an additional two open ports means that the public attack surface is broader that a normal website. Looking at the individual ports, the exposure of port 21-FTP which stands for file transfer protocol would reveal a risk as FTP is associated with file management and increase surface attack by giving too much to the public. Port 8080 is also used for alternate web servers, application interfaces, development services and admin panels and the exposure of this port would mean that an additional visible service besides the main website is present. Unnecessarily exposed services might increase attack surfaces and might give chances of reconnaissance (an early stage of information gathering for cyber attackers to plan their attack).

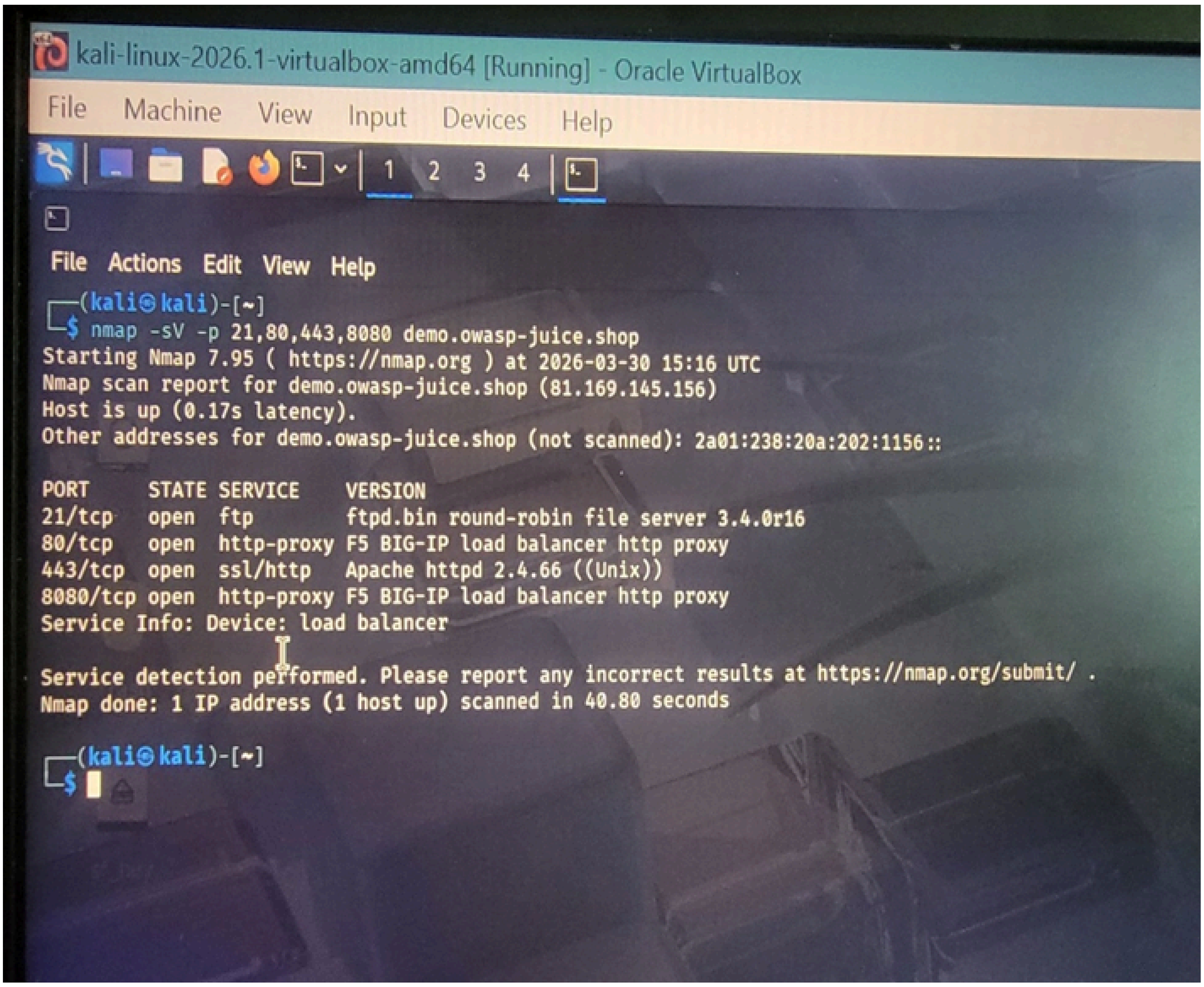
Nmap SCAN FINDINGS

Finding 1: Multiple Publicly Exposed Services

Recommendation (remediation steps): Assess whether the additionally exposed ports are required for the web service. If not required, disable or restrict the unnecessary ones as they may present greater vulnerabilities. If required, set aside a stronger security defense line to protect the site from exploitation. Publicly accessible file transfer service might expose legacy protocols so make sure whether the exposure of FTP scan is necessary or not and take important measure.

Nmap SCAN FINDINGS

Finding 2: Server and infrastructure fingerprinting possible



Nmap SCAN FINDINGS

Finding 2: Server and infrastructure fingerprinting possible

Risk level: Low

Explanation: Through the specific Nmap scan on the ports that were revealed to be open, Nmap revealed some of the infrastructure behind the server such as port 443 identified as Apache httpd 2.4.66, port 80 and 8080 identified as F5 BIG-IP load balancer and a likely Unix-based environment. As you can see from the scan results below, the scan disclosed the web server family version and the software information of the server which might help the attacker understand the environment better. This might give chances of reconnaissance. The target is externally finger printable.

Recommendation (remediation steps): Secure the infrastructure and prevent their visibility when necessary.

Findings from inspection through browser DevTools

Finding 1: Missing important security headers

Description: Through inspection of the demo website using the browser DevTools, I have found that there are some important/ crucial security headers missing

Missing header 1: Content-Security-policy header

Risk level: medium

Explanation: With this missing header, the browser has fewer restrictions on what can be run and the content that can be accessed. This might open the door for so many attacks such as XSS scripting and other injections.

Recommendations: Enable this header to restrict malicious scripts from running and prevent some browser centered attacks.

Findings from inspection through browser DevTools

Finding 1: Missing important security headers

Missing header 2: Strict-Transport-security

Risk level: medium

Explanation: This header tells the browser to always use https for this site. With missing such a header, while the browser may use https, it won't strongly enforce it if a client tried to access the site through http, so less protection.

Recommendation: Add or incorporate this header to allow secure transport exposure.

Missing header 3: Referrer policy

Risk level: low

Explanation: Missing this header might result in a leakage of browsing page origin information to external resources or linked end points.

Remediation: Set an appropriate referrer policy header

Findings from inspection through browser DevTools

Finding 1: Missing important security headers

Missing header 4: Permission policy

Risk level: medium

Explanation: This header doesn't allow this website to use some sensitive features unless permitted. But, missing it would result in an increased attack surface since features like camera, microphone, USB, payment and more are not secure and can be freely accessed. Malicious code can easily access the features of the site easily.

Remediation: Implement the permission-policy header and block features that aren't required for the site to function as they may increase attack surfaces.

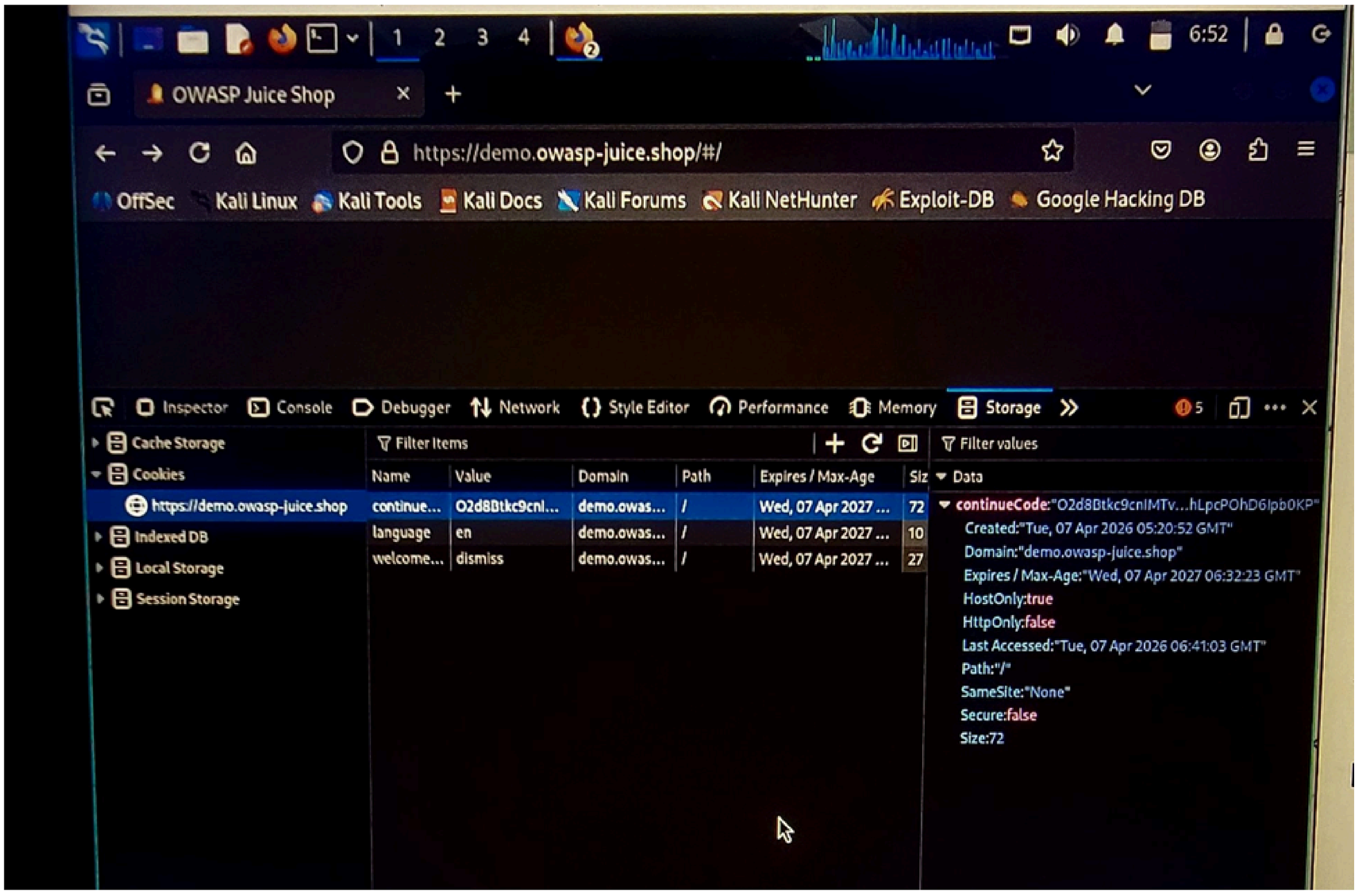
Findings from inspection through browser DevTools

Finding 2: Positive findings of security header analysis

Explanation: Two important security headers such as x-frame-options and x-content-type-options are present. Thus, the site is secure in cases of click jacking risks. Attackers might load a real website inside an invisible or transparent frame, so you might end up clicking an invisible button that would perform an authorized action if these headers aren't enabled. So, these headers are crucial in protecting the user from being deceived into clicking something different from what they think they are clicking.

Findings from inspection through browser DevTools

Finding 3: Insecure Cookie Attributes



Findings from inspection through browser DevTools

Finding 3: Insecure Cookie Attributes

Risk level: low

Explanation: the application sets cookies without the recommended cookie attributes such as Secure, HttpOnly and SameSite. Without these attributes of the cookie scripts may easily access it, and insecure http transmissions of the cookie may occur. They are configured in a way that can be observed on the picture in the previous page.

Recommendations: enable all the three cookie attributes to ensure safe transmission and secure sensitive cookies as cookies are like name tags that contain session information that should be kept secure.

CONCLUSION

This vulnerability assessment report have revealed some quite important web security weaknesses in the target demo website. These are configuration gaps in security headers, cookie handling, and browser side protections. Even if the test was conducted without any real exploitation the findings would help in strengthening the website's overall security and prevent exposure to common web based threats.

THANK YOU